

Oversight of Frederikshavn Municipality

Date: 22-12-2023

Decision

Public Authorities

Criticism

Serious Criticism

Oversight / Self-Operation Case

Processing Security

Fundamental Principles

Risk Assessment and Impact Analysis

The Data Protection Agency has made a decision in five oversight cases regarding the processing security in AULA. The Data Protection Agency found reason to issue orders for the preparation of impact analyses in two of the cases. Additionally, the oversight has expressed criticism and serious criticism in the cases.

Journal Number: 2023-423-0004.

Summary

The Data Protection Agency initiated oversight in the autumn of 2021 concerning the processing of personal data in the IT system AULA by a total of six selected municipalities. The oversight focused on compliance with the data protection regulation's rules on processing security and impact analysis.

"When schools/daycare institutions and parents communicate via AULA, sensitive and confidential information about children is often involved. It is therefore important that municipalities take good care of the information in AULA. According to the data protection regulation, children have a right to special protection," says Signe Vestergård, special consultant at the Data Protection Agency.

The Data Protection Agency has now made decisions in all cases except one, as this case contains some additional elements.

The oversight is a continuation of the Data Protection Agency's previous oversight of Kombit A/S (hereinafter KOMBIT) in December 2019. During that oversight visit, the Data Protection Agency found that KOMBIT could not be considered the data controller for AULA under Article 4, No. 7 of the data protection regulation. At the oversight meeting, the Data Protection Agency informed KOMBIT that KOMBIT should ensure that all municipalities were informed of their data responsibilities and that KOMBIT should transfer all necessary materials and information to the municipalities in this regard.

The Data Protection Agency finds that the oversight cases raise some general data protection legal issues across the municipalities, which can be better handled collectively rather than separately by the individual municipalities. Therefore, the Data Protection Agency has chosen to inform the Danish Municipalities Association (KL), the Agency for IT and Learning, and Kombit A/S (hereinafter KOMBIT) about the oversight's decisions in these cases. At the same time, the Data Protection Agency has formulated some recommendations for the further work on processing security in AULA.

Furthermore, the Data Protection Agency will provide the same recommendations in a letter to all municipalities in the country, where the oversight also informs about the decisions. The purpose of the information to the municipalities is to encourage them to consider whether the material gives rise to (further) assessments, etc., or to ensure the implementation of additional security measures regarding their processing of personal data in AULA.

Impact Analysis

Although the five municipalities use the same technical solution (AULA) for the same processing activities, they have had a markedly different approach to the issue of impact analyses.

All five municipalities have received criticism or serious criticism in the part of the cases concerning impact analysis. Two of the municipalities have received serious criticism for not having prepared an impact analysis. The Data Protection Agency has also issued these two municipalities an order to prepare an impact analysis within three months.

The other three municipalities have prepared impact analyses. The Data Protection Agency has reviewed them and assessed that none of them meet all the minimum requirements for an impact

analysis.

Additionally, the Data Protection Agency has examined the timing of the preparation of the impact analyses and taken into account that there has been uncertainty regarding the data responsibility for the processing of personal data in AULA. The municipalities and KOMBIT have thus been of the opinion that the data responsibility for the processing of personal data and the responsibility for conducting risk assessments and impact analyses lay with KOMBIT. However, the Data Protection Agency concluded during the oversight visit to KOMBIT in December 2019 that KOMBIT cannot be considered the data controller.

All three municipalities prepared the impact analyses only long after clarity regarding the data responsibility for the processing of personal data in AULA was established. Two of the municipalities even prepared the impact analyses only after the oversight had requested the material in connection with the initiation of the oversight, which is why the Data Protection Agency has expressed serious criticism towards these two municipalities. The Data Protection Agency has expressed criticism towards the third municipality.

Risk Assessment

All five municipalities have also received criticism or serious criticism regarding the part of the cases that concern the municipalities' risk assessment. The criticism relates to the documentation requirement to demonstrate that they have identified and mitigated the risks that the processing of personal data in AULA poses to the individuals concerned, ensuring an appropriate level of security. Furthermore, the criticism concerns the lack of identification and implementation of relevant measures to ensure an appropriate level of security.

The Data Protection Agency has expressed serious criticism of two of the municipalities, as they have not submitted actual risk assessments. One municipality stated in January 2023 that they had not yet completed the initial work of identifying relevant measures that can be implemented to ensure... regarding the identified high risks associated with the processing of personal data in AULA. The other municipality referred to a number of appendices as documentation for the mitigating measures the municipality had taken to reduce the risk for the registered individuals. The remaining three municipalities have submitted risk assessments. However, the Data Protection Agency has criticized these municipalities for not sufficiently demonstrating that they have ensured an appropriate level of security.

Several municipalities have submitted material from KOMBIT, where a number of high risks associated with the use of AULA have been identified. The municipalities have responded differently to the material. Some municipalities have stated that they have adopted KOMBIT's risk assessment and have based their descriptions of the measures they have implemented to reduce these risks on it. One municipality indicates that they have reviewed the material from KOMBIT but concluded that it could not immediately be used as a basis for actual risk assessments. Other municipalities have conducted their own assessments, where some of the risks they have identified are assessed to pose a lower risk than what is indicated in KOMBIT's material—however, without sufficiently documenting the basis for this assessment.

****Risk of Misdelivery in AULA****

The Data Protection Agency has found that a large portion of the reports of breaches of personal data security in AULA that the agency receives relate to the misdeliney of personal data to one or more incorrect recipients in AULA. This is also a risk that several municipalities have identified in their risk assessments. Several of the municipalities have implemented organizational measures aimed at informing users about this risk when sending messages via AULA. Additionally, one of the municipalities has also had a change request implemented in AULA, which allows for the deletion and editing of sent content in messages.

Despite these measures, the Data Protection Agency continues to receive a number of reports of breaches from municipalities that relate to misdeliney in AULA. It is generally the Data Protection Agency's opinion that data controllers who systematically use a technical functionality to send messages containing confidential and/or sensitive information should investigate whether it is possible

to implement one or more technical measures to reduce the risk of misdelivery. They should also explore options for designing the messaging function in a way that minimizes such risk.

In a letter to KL, KOMBIT, and the Agency for IT and Learning, the Data Protection Agency has recommended that KOMBIT, together with the data-controlling municipalities, conduct such an investigation. This recommendation will also be reiterated in a letter to all municipalities in the country.

****Joint Impact Assessment and Code of Conduct****

It is the Data Protection Agency's opinion that municipalities have the opportunity to prepare a joint impact assessment regarding data protection for their processing of personal data in AULA. This is based on the fact that the municipalities use the same type of system for the same processing activities of the same type of personal data, and that the municipalities' processing activities involve similar high risks. Furthermore, the system is provided by the same vendor.

In the letter to KL, KOMBIT, and the Agency for IT and Learning, the Data Protection Agency has therefore encouraged consideration across municipalities, and possibly in collaboration with KL and KOMBIT, to prepare a joint impact assessment regarding the municipalities' processing of personal data in AULA.

The Data Protection Agency has also recommended that KL, in collaboration with the municipalities and possibly KOMBIT, consider the possibility of developing a code of conduct in accordance with Article 40 of the General Data Protection Regulation regarding the municipalities' processing of personal data in AULA. The Data Protection Agency has noted that this consideration may also be relevant for other processing activities in the municipalities, where they use the same system for the same processing activities of the same types of personal data, which involve similar high risks.

A code of conduct can provide correct and practical guidance on how to organize oneself in connection with one or more processing activities to comply with data protection regulations. This could, for example, involve establishing procedures that must be followed for a specific processing activity. A code of conduct would therefore be a useful tool to help comply with data protection regulations for the authorities that have subscribed to the code.

Although it facilitates compliance with the regulations, it does not exempt the individual data controller from the obligations and tasks that fall upon them as data controllers. This is particularly significant in situations where the data controller chooses to deviate from the assumptions in the common concepts and processes—for example, by using a system for other purposes.

“It is a large and resource-intensive task for individual municipalities to conduct risk assessments and impact assessments that ensure the appropriate security measures. But it is necessary. AULA is a tool used in all municipalities for the same processing activities of the same type of personal data. We therefore encourage the municipalities—possibly in collaboration with KL and KOMBIT—to come together and ensure that citizens' information in AULA is adequately protected,” says Signe Vestergård, special consultant at the Data Protection Agency.

1. **Written Supervision of Frederikshavn Municipality Regarding the IT System AULA**

Frederikshavn Municipality is among the municipalities that

****Data Protection Authority Oversight Report****

In the autumn of 2021, the Data Protection Authority selected to conduct oversight in accordance with the General Data Protection Regulation[1] and the Data Protection Act[2]. The oversight by the Data Protection Authority is a written review with a particular focus on the technical and organizational security measures that have been observed to meet the requirement for an appropriate level of security for the processing activities in the IT system AULA. This oversight is a continuation of the Data Protection Authority's previous oversight of Kombit A/S (hereinafter referred to as KOMBIT) in December 2019, where the oversight visit found that KOMBIT is not to be regarded as the data controller for AULA under Article 4, No. 7 of the General Data Protection Regulation. Therefore, the Data Protection Authority informed KOMBIT that KOMBIT must ensure that all municipalities are informed of their data responsibilities and that KOMBIT provides the municipalities with all necessary

materials and information in this regard. The Data Protection Authority expects that KOMBIT has informed the municipalities about this immediately after the oversight visit in December 2019.

****2. Decision****

After a sample review of KOMBIT's risk assessment and a review of Frederikshavn Municipality's risk assessment in their impact analysis, the Data Protection Authority finds that Frederikshavn Municipality has demonstrated that it has identified and assessed the most significant risks that the municipality's processing of personal data in AULA poses to the data subjects. Frederikshavn Municipality is thus seen to have documented how it has assessed the risk to the data subjects from the relevant processing activities.

However, it is the Data Protection Authority's assessment that Frederikshavn Municipality has not demonstrated that the measures implemented to reduce the risk associated with the processing of personal data in AULA are sufficient to lower the risk from high to medium. It is therefore the Data Protection Authority's assessment that Frederikshavn Municipality has not sufficiently demonstrated that it has ensured a security level that is appropriate to the risks posed by the processing of personal data in AULA. The Data Protection Authority therefore criticizes that Frederikshavn Municipality's processing of personal data has not been carried out in accordance with Article 5, Paragraph 2, in conjunction with Paragraph 1, Letter f, and Article 24, Paragraph 1, in conjunction with Article 32, Paragraph 1 of the General Data Protection Regulation.

Furthermore, it is the Data Protection Authority's assessment that Frederikshavn Municipality has not conducted a sufficient impact analysis, cf. Article 35, Paragraph 1 of the General Data Protection Regulation, as the submitted impact analysis does not meet the minimum requirements set out in Article 35, Paragraph 7, Letters a and d of the Regulation. The Data Protection Authority also finds that Frederikshavn Municipality, by having prepared an impact analysis for the processing of personal data in AULA nearly three years after it became clear that the municipality is the data controller for processing personal data in a solution that involves a high risk for the data subjects, has acted in violation of Article 35, Paragraph 1 of the General Data Protection Regulation. The Data Protection Authority finds it serious that the impact analysis appears to have been prepared only after the Data Protection Authority requested the material as part of the written oversight in the area.

On this basis, the Data Protection Authority further finds grounds to express serious criticism that Frederikshavn Municipality's processing of personal data has not been carried out in accordance with Article 35, Paragraph 1 of the Regulation.

****3. Case Presentation****

The Data Protection Authority, by letter dated October 15, 2021, announced the oversight of Frederikshavn Municipality. In this context, the Data Protection Authority requested the municipality to submit the following:

1. The risk assessments that form the basis for the assessment of what security is deemed appropriate for the processing of information about individuals in "AULA," as well as a description of the general security models in the application.
2. To the extent that impact analyses have been prepared, copies of all versions of these.
3. A review of considerations regarding the use of Article 25 of the General Data Protection Regulation in connection with the acquisition and development of "AULA."
4. A review of authorization and access control models.

Frederikshavn Municipality submitted a statement regarding the case along with a number of attachments on November 5, 2021. The Data Protection Authority then received Frederikshavn Municipality's resubmission of the material on November 16, 2021, which it was not possible for the Data Protection Authority to open during the first submission. Subsequently, on November 4, 2022, Frederikshavn Municipality submitted updated material, including an updated impact analysis, based on updated risk assessments and a template for impact analysis, in agreement with the Data Protection Authority. In this connection, Frederikshavn Municipality also submitted material that had

not previously been submitted due to an error.

Based on the statements from the six selected municipalities, the Data Protection Authority has chosen to limit the focus of the oversight to questions regarding risk assessment and impact analysis. It should be emphasized in this context that the Data Protection Authority has not, in connection with this oversight, taken a position on whether Frederikshavn Municipality's processing of personal data in AULA is in accordance with Article 25 of the General Data Protection Regulation regarding data protection by design and by default, or whether the municipality's authorization and access control models are in accordance with the General Data Protection Regulation.

****Article 32.****

The Data Protection Authority has subsequently, by letter dated December 9, 2022, posed a series of clarifying questions to Frederikshavn Municipality regarding any mitigating measures that the municipality has implemented. Frederikshavn Municipality responded to these questions on January 10, 2023.

****3.1. General Information on the Decision and Development of AULA****

The Danish Municipalities Association (hereinafter KL) states on their website that the municipal procurement of AULA is part of the User Portal Initiative, which is a political initiative from 2013.[3] It further states that AULA aims to support communication and thereby collaboration regarding children's learning and well-being in a secure and user-friendly manner. KL also informs that all 98 municipalities in Denmark jointly participated in a common tender for a collaboration platform – the later AULA – for the school sector in 2016. AULA was put out to tender by the municipalities' IT community, KOMBIT A/S (hereinafter KOMBIT), at the beginning of 2017, and the choice fell on the supplier Netcompany – IT and Business Consulting, which has since developed AULA in collaboration with the companies Frog, EduLab, and Advice. KOMBIT provides information about AULA on the website aulainfo.dk. It appears that the majority of primary schools began using AULA in 2019 and daycare facilities in the winter of 2020/2021.[4] The Data Protection Authority assumes that the individual municipalities are independently responsible for their processing of personal data in AULA, and that KOMBIT, which is the data processor for the municipalities, has entered into a data processing agreement with Netcompany, which is thus a sub-processor.[5]

****3.2. Comments from Frederikshavn Municipality****

****3.2.1. Risk Assessment****

Frederikshavn Municipality has stated that in 2018 they assessed that the risk assessments for AULA, conducted by KOMBIT, were sufficient and did not deviate from the municipality's assessments. Therefore, Frederikshavn Municipality has chosen to use KOMBIT's risk assessments as the basis for the necessary security level in AULA. Frederikshavn Municipality has referred in their statement to five of their submitted appendices with risk assessments of five different data processes in AULA (Data Process 1: Administration of users and groups, Data Process 2: Login and user information, Data Process 3: Communication and collaboration in primary schools, Data Process 4: Communication and collaboration in daycare facilities, Data Process 5: Sharing of information with other IT solutions). It appears from a memorandum dated September 11, 2018, titled "AULA Risk Assessments from KOMBIT," which the Data Protection Authority has received from Frederikshavn Municipality, that it is the assessment of Frederikshavn Municipality's data protection advisor that KOMBIT's risk assessments for the following areas are sufficient: Administration of users and groups, Login and user information, Communication and collaboration in primary schools/daycare facilities, and Sharing of information with other IT solutions. The following is also stated in the memorandum: "Highest threat - A wide range of risks are linked to the human factor, behavior from users." Subsequently, mitigating measures as a result of the risk assessments have been proposed concerning internal users. It is stated that users should be educated on good behavior regarding information security/GDPR. Regarding this education, the following is stated in the memorandum: "This education can, among other things, take place for the superuser, and specific areas can be communicated by the data protection advisor. These are topics that fall under the category of Safe Behavior, e.g.: Handling of codes, Where one may store which documents, Suspicion of hacking – procedure for this." The

memorandum also contains proposals for mitigating measures concerning external users (parents). The following is stated in the memorandum in this connection: "In connection with implementation, it would be appropriate for the municipality to prepare a brief information guide for parents on handling codes at home. The municipality imposes a formal as well as an ethical data responsibility when implementing the system, which also extends into the homes, and the municipality should take on this task to ensure the highest security level for AULA. In behavior and use of AULA both in schools/daycare facilities and at home, Frederikshavn Municipality is a catalyst." Regarding other risks that are not linked to user behavior, the following is stated in the memorandum: "Risks such as hacking, process errors, technical threats, etc., must be handled by IDV. Here, a meeting is held with the department head for IT to discuss technical security measures." Frederikshavn Municipality further stated that in connection with the inquiry from the Data Protection Authority, they contacted KOMBIT and received the latest risk assessments for AULA. Frederikshavn Municipality has referred to five Excel sheets with risk assessments of the five aforementioned data processes. Additionally, Frederikshavn Municipality has referred to 12 Excel sheets with risk assessments of various modules in AULA, as well as 12 documents titled "Assessment of Risk and Consequence – Module XX," which pertain to the various modules in AULA. Based on a sample review, the Data Protection Authority has determined that the attached material from KOMBIT generally establishes that a number of processing activities carried out in AULA involve a high risk for the data subjects. It further appears from the material that it is expected/probable that a number of scenarios will occur, which involve consequences categorized as "destructive" or "very serious." It is stated, for example, in KOMBIT's risk assessment for...

of the analysis is there a summary of the identified risks. Each risk is described in detail, including the potential consequences and the likelihood of occurrence.

The document also outlines that Frederikshavn Municipality has implemented various measures to mitigate these identified risks. These measures include training for users on data handling and classification, as well as establishing clear access policies and practices for user management in AULA. The municipality is committed to ongoing monitoring and documentation to prevent unauthorized access and ensure the security of user data.

In conclusion, the analysis indicates that while Frederikshavn Municipality has recognized and documented high risks associated with AULA, it is also taking steps to address these risks through training, policy implementation, and continuous oversight.

****3.2.2. Impact Assessment****

Frederikshavn Municipality informed the Data Protection Agency on November 5, 2021, that the municipality had begun drafting the impact assessment, but that it was not yet completed, as the replacement of the municipality's data protection officer had caused delays in certain tasks.

The Data Protection Agency received Frederikshavn Municipality's impact assessment on November 4, 2022.

The impact assessment is dated November 3, 2022.

It appears from the document's version control that the first version was sent to the municipalities on January 28, 2020, and that KOMBIT has made corrections in later versions. The Data Protection Agency therefore assumes that Frederikshavn Municipality's impact assessment has been prepared based on a draft/template from KOMBIT.

The impact assessment contains tables and figures, and references are made to the risk assessments of the five data processes and 12 modules in AULA, which are mentioned above under section 3.2.1.

The first section of the impact assessment contains a summary. The following is stated, among other things, in the section regarding the municipality's system owner's assessment of the impact assessment:

"It is my opinion that the impact assessment correctly reflects the procedures and frameworks that have been communicated at the municipal level regarding compliance with personal data processing in AULA.

On this basis, I have approved the impact assessment."

****3.2.1. Risk Assessment****

As part of the impact assessment, a risk assessment has been conducted, which has been assessed as "low" (green). In this context, it is stated that the content of each individual risk assessed as "high" or "medium" has been explained, as well as why it constitutes a risk for the data subjects. However, the Data Protection Agency can ascertain that it is only the 27 high risks that are elaborated upon in the impact assessment, and that there is no further explanation for the risks that the municipality has assessed as "medium."

In section 6.3.1 of the impact assessment, Frederikshavn Municipality has conducted a risk scoring in relation to likelihood and consequence, where a value from one to four is indicated, and based on this, an overall risk scoring has been made.

Section 6.2 of the impact assessment contains a description of the four evaluation criteria for likelihood and consequence, respectively. The four evaluation criteria used in the impact assessment for likelihood are "Expected," "Likely," "Less likely," and "Unlikely," and the four evaluation criteria used for consequence are "Destructive (Very Critical)," "Very Serious (Critical)," "Less Serious (Annoying)," and "Insignificant (Irrelevant)." It is stated in this context that the evaluation criteria match the criteria used in the risk assessments for AULA, and that Frederikshavn Municipality uses KOMBIT's risk assessments.

Furthermore, Frederikshavn Municipality's impact assessment includes a figure with a risk map. It is stated in this context that the risk map shows the number of identified risks for the general risk assessment for the five data processes and the 12 specific risk assessments for AULA, shown in relation to likelihood and consequence. It is further stated that the figure reflects the risk assessment that the municipality has reached prior to the municipality's implementation of mitigating measures in AULA.

Section 7.3 of the impact assessment, titled "Residual Risk," contains the aforementioned table titled "Residual Risk Scoring." The table contains for each of the 27 high risks a description of the municipality's choice of measure to manage the risk, an assessment of the effect on the risk, an indication of the residual risk, and information on whether the measure has been implemented. The Data Protection Agency can ascertain that Frederikshavn Municipality has assessed that the effect of the implemented measures for all 27 high risks is that the risk has been reduced to "medium." The Data Protection Agency has examined the table's fields concerning the three high risks identified in the messaging module in AULA (risk no. 15, 16, and 17), which are also mentioned above in this section in relation to KOMBIT's risk assessment for the messaging module in AULA.

Risk no. 15 concerns user behavior that leads to mishandling of personal data in the system, carried out by an authorized user through unintentional disclosure of personal data in the application. In relation to this risk, it appears from the "Residual Scoring" table that Frederikshavn Municipality has chosen the following measure to manage the risk: "Training has been provided on the rules regarding GDPR for all superusers and pedagogical staff during onboarding of the system. The superusers and department heads are responsible for training new employees in AULA."

Risk no. 16 concerns unintentional process errors that lead to incorrect handling due to incorrect or missing implementation of data classification in the solution. It is further described as a leak of sensitive data due to incorrect (too low) or missing data classification. In relation to this risk, it appears from the "Residual Risk Scoring" table that Frederikshavn Municipality has chosen the same measure as for risk no. 15 (training).

Risk no. 17 concerns unintentional process errors where there are incorrect accesses due to missing or unclear policies. In relation to this risk, it appears from the "Residual Scoring" table that Frederikshavn Municipality has chosen the following measure to manage the risk: "Creation of users and deletion of users in the user administrative systems is a manual process; it is the responsibility of the managers to continuously check the users in daily practice, especially upon termination of employment."

Furthermore, the following is stated regarding the municipality's data protection advisor's assessment of the impact assessment:

"It is evident through risk assessments conducted for both the solution's functionalities and data flows

that the most significant risks arise from a lack of knowledge about the rules concerning the processing of personal data and the rights within the solution.

It is the data protection advisor's assessment that the municipality's use of the data processor's risk assessments and impact analysis has provided the desired overview of the processing of personal data and whether the implemented measures, such as access control procedures, training, and awareness, have been sufficient to reduce the high residual risk.

With the reduction from high to medium risk, it is the data protection advisor's assessment that the Data Protection Agency does not need to be consulted in a prior Art. 36 hearing.

The data processor has its processing of personal data in the solution audited annually by an independent third party, which the municipality then assesses and follows up on. Likewise, the municipality receives updated risk assessments from the data processor, which the system owner uses in the annual evaluation of the solution."

The impact assessment also contains a section 9 titled "Documentation of the DPO's Views," where it is stated that the school sector has asked the data protection advisor to assess the advantages and disadvantages of drafting the impact assessment based on KOMBIT's template and the associated risk assessments compared to drafting a new self-developed impact assessment based on its own risk assessments. It is further stated that Frederikshavn Municipality has chosen to use the received risk assessments and the impact assessment template from the data processor (KOMBIT). The following is noted regarding the background for this choice:

"This choice was made because the AULA solution is such a complex solution in which all types of personal data are expected to be processed, and because the Data Protection Agency's desire to see the latest impact assessment, in connection with the ongoing written supervision of the solution, meant that it was not possible to prepare its own risk assessments in a timely manner."

Furthermore, the following is stated in the section on the documentation of the data protection advisor's views:

"The municipality assessed at the implementation of the solution that the risks identified by KOMBIT with a residual risk of 'high' lay in human handling of the solution. The municipality's focus and solution for mitigating actions were therefore centered around managing access through procedures, as well as training and awareness of both staff and students.

Through the implementation of organizational measures, the municipality has assessed that the critical and/or very critical risks, with a probability that was above 'Less likely,' were reduced so that the residual risk ended up at 'medium,' and the Data Protection Agency will therefore not be consulted in a prior Art. 36 hearing.

In the internal audit procedure "Management Oversight of Information Security," the data protection advisor reviews, among other things, selected centers' documentation for compliance with procedures at the end of the year. The data protection advisor therefore expects to be able to review the impact of the measures in the use of Aula together with the system owner in the coming year."

In section 3 of the impact assessment, the process for conducting the impact assessment is described, including the method and involvement of the data subjects. It is stated, among other things, that representatives of the data subjects have been involved, and that their views have been heard regarding the planned processing. In this context, it is noted that the following have been involved: the Agency for IT and Learning, employees, parents, municipalities (regarding the requirements specification), the Danish Teachers' Union, the association School & Parents, FOA, Danish School Students, and BUPL.

Section 4 of the impact assessment contains a description of the planned processing. In the section, various questions about the nature, scope, context, and purpose of the processing are answered.

Section 5 of the impact assessment is titled "Assessment of Necessity and Proportionality." In this context, reference is made to Article 35, paragraph 7, letter b of the Data Protection Regulation. In the section, various questions regarding the principle of legality, fairness, and transparency, the principle of purpose limitation, the principle of data minimization, the principle of accuracy, the principle of storage limitation, processing security, the rights of the data subjects, the relationship with data processors, and the transfer of personal data to third countries and international organizations are answered.

Frederikshavn Municipality has, among other things, addressed questions regarding the legal basis for the processing activities, whether the purpose can be achieved by limiting – possibly entirely avoiding – the processing of personal data, how it is ensured that personal data is recorded correctly, whether there is an overview of whom personal data is shared with, and how compliance with the various rights is ensured.

In the municipality's response to questions regarding the principle of storage limitation, reference is made to a policy for deletion rules and deletion procedures in AULA, which is available on the website aulainfo.dk.

Furthermore, Frederikshavn Municipality has answered questions about the use of data processors and sub-processors, and how it is ensured that they comply with the requirements for data processors in the Data Protection Regulation. Following this, Frederikshavn Municipality's response to questions about the transfer of personal data to third countries and international organizations is provided.

****6. Risk Identification and Evaluation****

The section 6 of the impact assessment concerns the identification and evaluation of risks, and section 7 concerns the identification of measures to manage risks. These sections are further discussed under item 3.2.1 above.

In section 8 of the impact assessment, it is stated that based on the new overall residual risk, Frederikshavn Municipality's assessment is that there is no obligation to conduct a prior consultation with the Data Protection Authority.

Section 10 of the impact assessment indicates that management has decided to approve that processing may commence, provided that the mitigating measures outlined in the impact assessment are implemented.

Finally, it is stated in section 11 of the impact assessment that the impact assessment will be maintained/updated annually, and which employee will carry out the update.

****3.3. Reported Breaches of Personal Data Security Regarding AULA****

The background for the Data Protection Authority's initial decision to supervise municipalities with a particular focus on the technical and organizational security measures observed to meet the requirement for an appropriate level of security for the processing in AULA is that the authority has seen (and continues to see) a number of reported breaches of personal data security in connection with the processing of personal data in AULA.

In AULA, personal data is processed, including confidential and sensitive personal data about vulnerable individuals, including children. Furthermore, the system's users are often individuals who do not primarily work with data protection (including educators, pedagogical staff, as well as students and parents), which, in the authority's view – in light of the many reported breaches from the vast majority of the country's municipalities – may imply that stricter requirements should be imposed on the data controllers' observance of both technical and organizational measures, cf. Article 32, as well as mitigating measures for compliance with Article 25 of the regulation.

A significant portion of these reports of breaches of personal data security in AULA concerns the fact that personal data has been sent to one or more incorrect recipients in AULA. For example, where a message or secure file about a child has been sent to another child's parents, or where a message has been mistakenly sent to a group of recipients instead of a specific recipient. The Data Protection Authority has also seen instances where, when sending documents to one or more parents, an incorrect document containing information about another child has been attached. Thus, there have been several unintended disclosures of personal data about children in AULA, including descriptions of children's concentration difficulties, recommendations for pedagogical-psychological assessment, information about dyslexia, school statements, as well as action plans and assessments regarding educational readiness.

By searching in the Data Protection Authority's ESDH system, the authority can confirm that it has received three reports of breaches of personal data security from Frederikshavn Municipality under Article 33 of the Data Protection Regulation, where AULA is mentioned in the report.

The first of the reports concerns unauthorized access to information, where a student has shared their login information for AULA with another person, who has logged into AULA and exploited the

information available to them.

The second report concerns the unintended disclosure of personal data about a student in a message sent to the students in a class instead of to a teacher at the school. The message contained information about the teacher's concern for a student.

The third report concerns the unintended disclosure of personal data about a student in a message that was supposed to be sent to the respective student's parents but was instead sent to some other parents. The message contained information about the student's difficulties as well as information about a referral to Pedagogical Psychological Counseling (PPR). Additionally, the message contained health information about one of the student's parents and siblings.

****4. Justification for the Data Protection Authority's Decision****

****4.1. Risk Assessment****

The Data Protection Authority assumes that Frederikshavn Municipality has endorsed the submitted risk assessments for AULA, which KOMBIT has prepared, and that Frederikshavn Municipality has addressed the risks identified in the risk assessments in their impact assessment.

****4.1.1. Relevant Regulations****

The Data Protection Regulation requires, in several respects, that a data controller addresses the risk to the rights and freedoms of the data subjects and can document the considerations and conclusions this has led to.

It follows directly from the provisions in Articles 5, paragraph 1, letter f, 24, 25, 32, 33, 34, 35, 36, and 39, that the data controller must address the risk to the rights and freedoms of the data subjects.

Furthermore, it follows from both Article 5, paragraph 2 regarding the principles in Article 5, paragraph 1, and Article 24 regarding compliance with the entire regulation, that a data controller must be able to demonstrate compliance with data protection rules.

Among other things, Articles 25, 35, and 36 require that considerations regarding the involved risks to the rights of the data subjects must take place before the processing is initiated.

It follows from Article 5, paragraph 1, letter f of the Data Protection Regulation that personal data must be processed in a manner that ensures adequate security for the personal data in question, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures.

****4.1.1. Responsibilities of the Data Controller****

The data controller must also be able to demonstrate that the fundamental principles are being complied with, as stipulated in Article 5, paragraph 2 of the General Data Protection Regulation (GDPR). According to Article 32, paragraph 1 of the GDPR, the data controller must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risks associated with the data controller's processing of personal data.

It follows from Article 24, paragraph 1 of the GDPR that a data controller must implement appropriate technical and organizational measures to ensure and to be able to demonstrate that the processing is in compliance with the regulation. The data controller has an obligation to identify the risks that the data controller's processing poses to the data subjects and to ensure that appropriate security measures are introduced to protect the data subjects from these risks.

Furthermore, the data controller must be able to demonstrate that personal data is processed in a manner that ensures adequate security for the individuals to whom the data relates. In order for the supervisory authority to assess whether an appropriate level of security has been ensured, it must be documented and explained which risks the data controller has identified and what mitigating measures have been taken to reduce these risks.

****4.1.2. General Requirements for Risk Assessment****

The Data Protection Authority notes that the GDPR does not specify how detailed the risk assessment must be. It is the opinion of the Data Protection Authority that the data controller must establish an appropriate level considering the risks that are relevant to the data controller's processing of personal data.

If a supplier, data processor, or available analyses determine or indicate specific risk scenarios, it is the opinion of the Data Protection Authority that data controllers should take these assessments into account, especially when processing activities in a system are deemed to involve high risks for the data subjects. At a minimum, there must be a substantiated assessment of why the matter is not relevant in the processing of personal data that occurs with the data controller.

It is not explicitly stated anywhere in the GDPR how the documentation should look, what the specific content should be, or what the frequency of updating and revision should be. The Data Protection Authority's view is that the documentation obligation implies that the supervisory authority – from the total material that the data controller can present – can assess whether the processing is in compliance with the GDPR. Thus, it should be evident from the presented material how and on what basis the data protection considerations have been made. This includes, among other things, the legality of the processing and the ability to ensure compliance with the rights of the data subjects, adherence to the data protection principles, and ensuring an appropriate level of security.

Additionally, it should be clear what considerations, choices, and omissions have been made to ensure that the processing of the information is in compliance with the GDPR. In this context, it should be possible to timestamp when and with what content relevant considerations and actions have occurred.

It is the opinion of the Data Protection Authority that a risk assessment should include an evaluation of the consequences (e.g., high, medium, low) for the data subjects in the event of loss of confidentiality, availability, and integrity. Subsequently, the risk assessment should identify what threats exist for the loss of confidentiality, availability, and integrity, as well as the likelihood (e.g., high, medium, low) that the threat will materialize. Finally, the risk assessment should map the existing security measures and their contribution to reducing the risk. On this basis, the data controllers can assess the risk and determine whether it is an acceptable risk or whether further measures should be implemented. By addressing these elements in a risk assessment, the data controllers can document how they have assessed the risk to the data subjects from the relevant processing activities, as well as on what basis they believe that the implemented measures have reduced the risk.

****4.1.3. Frederikshavn Municipality's Identification and Assessment of Risks****

Following a sample review of the submitted risk assessments from KOMBIT regarding the five data processes and 12 modules in AULA, as well as a review of the submitted impact assessment, the Data Protection Authority can confirm that Frederikshavn Municipality has identified a number of risks, including 27 high risks, 195 medium risks, and several low risks, which Frederikshavn Municipality assesses that the processing of personal data in AULA poses for the data subjects. In this context, Frederikshavn Municipality appears to have made an assessment of the consequences for the data subjects in the event of loss of confidentiality, integrity, and availability, as well as an assessment of the likelihood that the threats will materialize. The impact assessment has accounted for the four different evaluation criteria for both likelihood and consequence.

On this basis, the Data Protection Authority finds that Frederikshavn Municipality has demonstrated that it has identified and assessed the most significant risks that the municipality's processing of personal data in AULA poses for the data subjects. Frederikshavn Municipality thus appears to have documented how they have assessed the risk for the data subjects from the relevant processing activities.

registered with the relevant processing activities.

4.1.4. Description of Security Measures by Frederikshavn Municipality

KOMBIT's risk assessments do not appear to contain a description of the measures that are or will be implemented to reduce the identified risks. However, such a description is included in Frederikshavn Municipality's impact assessment concerning the 27 high risks. It is stated in section 7.1 of Frederikshavn Municipality's impact assessment that for each identified risk – assessed as high or medium – it is indicated whether the risk has been eliminated, reduced, or accepted. Upon reviewing Frederikshavn Municipality's description of measures, the Data Protection Agency can ascertain that Frederikshavn Municipality has described their choice of measures to manage the risk concerning the

27 high risks, indicated what the effect of the measures is, and specified what the residual risk is after the implemented measures. In relation to all the high risks, it is indicated that the effect is that the risk has been reduced from high to medium.

However, it is not clear how Frederikshavn Municipality has assessed the risk after the implemented measures. The Data Protection Agency assumes that the municipality has assessed that the likelihood has been reduced as a result of the implemented measures. This is partly based on what is stated in section 9 of the impact assessment with documentation of the data protection advisor's views, where it is indicated that through the implementation of organizational measures, the municipality has assessed that the critical and/or very critical risks with a likelihood that was above "Less likely" have been reduced, such that the residual risk ended up at "medium."

It is also not clear how likely the municipality assesses it is that the individual threats materialize after the implemented measures based on their evaluation criteria for likelihood (expected, likely, less likely, or unlikely). Assuming that the reduced risk is due to a reduced likelihood, it is, however, possible from the risk map in the impact assessment to determine what Frederikshavn Municipality has assessed the likelihood has been reduced to concerning the individual risks after the municipality has implemented the listed measures.

Furthermore, Frederikshavn Municipality does not appear to have addressed in the impact assessment whether mitigating measures should be implemented concerning the 195 medium risks. It is stated in Frederikshavn Municipality's impact assessment that management has approved that processing can commence, provided that the mitigating measures in the impact assessment are implemented. The mitigating measures described in the impact assessment only concern the 27 high risks. The Data Protection Agency thus assumes that management has accepted the 195 medium risks.

Additionally, the Data Protection Agency has found, through an overall review of the described measures, that the measures appear to be relevant for reducing the various risks. However, it is not clearly stated whether the various measures are sufficient to reduce the relevant risks from high to medium.

It is stated in section 9 of the impact assessment with the heading "Documentation of the DPO's Views" that the municipality's focus and solution for mitigating actions have been centered around managing access through procedures, as well as training and awareness of both staff and students. In this regard, the Data Protection Agency has noted that the majority of the implemented measures are organizational measures. As an example, the Data Protection Agency can mention that Frederikshavn Municipality has stated the following measure regarding training on the General Data Protection Regulation for super users and in connection with onboarding of employees as the only measure implemented to reduce 16 of the 27 high risks:

"There has been training on the rules regarding GDPR for all super users and pedagogical staff during the onboarding of the system. The super users and department heads are responsible for training new employees in Aula."

The Data Protection Agency has subsequently specifically reviewed the measures described concerning the three high risks that the processing of personal data in AULA's messaging module entails. These risks are also highlighted above under point 3.2.1.

Regarding risks 15 and 16

Concerning the first two of these risks (user behavior leading to mishandling of personal data in the system, carried out by an authorized user due to unintentional disclosure of personal data in the application and unintentional process errors leading to incorrect handling due to incorrect or missing implementation of data classification in the solution), the aforementioned measure regarding training on the General Data Protection Regulation is indicated as the only measure.

It is stated in the impact assessment that Frederikshavn Municipality assesses that these risks have been reduced to medium after the implemented measures. Based on the risk map in the impact assessment, the Data Protection Agency assumes that Frederikshavn assesses that the likelihood has been reduced from the category "Expected" to the category "Less likely" after the implemented measures.

However, the Data Protection Agency can ascertain that there is at least in one case no clear

correlation between what is described in the impact assessment.

****Regarding the criteria for assessing the likelihood and the realized risks.****

The evaluation criteria in the impact analysis for likelihood in relation to the category "Less Likely" are as follows:

*****"Less Likely: The event may risk occurring.****

There is internal experience with the event from a few years ago.

Known from other public and private companies in Denmark."

In comparison, the Data Protection Agency can mention that the evaluation criteria for likelihood in relation to the category "Likely" are as follows:

*****"Likely: It is likely that the event will occur.****

- There is internal experience with the event, but not within the last 12 months.

- Known from other public and private companies in Denmark (the type of event is mentioned annually in the press)."

In this context, the Data Protection Agency notes that the agency, as mentioned above under point 3.3, has found that Frederikshavn Municipality has reported a breach of personal data security to the Data Protection Agency regarding the unintentional disclosure of personal data about a student in a message that was supposed to be sent to the respective student's parents but was instead sent to other parents. The incident occurred on March 4, 2022, and thus approximately eight months before the preparation of the impact analysis, which is dated November 3, 2022.

Furthermore, the Data Protection Agency notes that the agency continues to regularly receive reports of breaches of personal data security in AULA from the country's municipalities, including incidents where information is unintentionally disclosed to unauthorized parties in, for example, messages. Frederikshavn Municipality does not appear to have addressed the risk that students and parents of children in schools and daycare institutions, who are part of the authorized users in AULA, send a message containing (sensitive or confidential) personal data to incorrect recipients.

In this context, it is noted that it is stated in the submitted document titled "Assessment of Risk and Consequence – Message Module" that KOMBIT assesses that all municipalities must ensure that all users (and thus not only super users and employees being onboarded) are trained to avoid unintentional disclosure of personal data in messages in AULA and in how they handle and correctly classify sensitive messages in the message module. Frederikshavn Municipality has not addressed KOMBIT's assessment of what measures municipalities should implement in their risk assessment in the impact analysis. Thus, Frederikshavn Municipality has not provided a detailed explanation of why the measure is not relevant in relation to Frederikshavn Municipality's use of AULA.

On this basis, the Data Protection Agency finds that Frederikshavn Municipality has not demonstrated that the municipality, solely by implementing training on the General Data Protection Regulation for super users and through onboarding, has ensured that the likelihood of unintentional disclosure of personal data to unauthorized parties in AULA's message module, for example, by sending a message to an incorrect recipient, has been reduced from "Expected" to "Less Likely," thereby reducing the risk from high to medium.

****Regarding Risk 17****

In relation to the third risk concerning the message module, which is highlighted above in section 3.2.1 (unintentional process errors where there are incorrect accesses due to lack of or unclear policies), the following measure is indicated in the impact analysis:

*****"Creation of users and deletion of users in the user administrative systems is a manual process; it is the responsibility of the managers to continuously check the users in daily practice, especially upon termination of employment."*****

It appears from the impact analysis that Frederikshavn Municipality assesses this risk as medium after the implemented measures. Based on the risk card in the impact analysis, the Data Protection Agency assumes that Frederikshavn assesses that the likelihood has been reduced from the category

"Expected" to the category "Less Likely" after the implemented measure.

The Data Protection Agency notes that it is stated in the submitted document titled "Assessment of Risk and Consequence – Message Module" that KOMBIT assesses that all municipalities must have a clear access policy and practice for ongoing user administration in AULA, with particular focus on continuously maintaining user or system access when changes occur due to altered employment conditions and changed integrations to AULA. Frederikshavn Municipality has not addressed KOMBIT's assessment of what measures municipalities should implement in their risk assessment in the impact analysis. Thus, Frederikshavn Municipality has not provided a detailed explanation of why the measure is not relevant in relation to Frederikshavn Municipality's use of AULA.

The Data Protection Agency finds that Frederikshavn Municipality has not demonstrated that by merely referring to the fact that the creation and deletion of users is a manual process, and that it is the managers' responsibility to continuously check user accesses in daily practice, especially upon termination of employment, it has ensured that the likelihood of incorrect accesses to the information in AULA has been reduced from "Expected" to "Less Likely," thereby reducing the risk from high to medium.

In this regard, the Data Protection Agency has particularly emphasized that it does not appear from the impact analysis that procedures have been established for regular checks of authorizations and established accesses.

****4.1.5. Specifically regarding the risk of erroneous transmission****

i AULA's Messaging Module

It is generally the Data Protection Agency's view that data controllers who systematically use a technical functionality to send messages containing confidential and/or sensitive information should investigate whether it is possible to implement one or more technical measures to reduce the risk of erroneous transmission, or whether it is possible to design the messaging function in a way that minimizes such risk.

On this basis, the Data Protection Agency recommends that Frederikshavn Municipality, together with KOMBIT and the other data-controlling municipalities, conduct such an investigation. This is particularly relevant considering that AULA's users are often individuals who do not primarily work with data protection (teachers, educational staff, and parents), which, in the Agency's view—given the many reported breaches—may imply that stricter requirements should be imposed on the data controller's observance of both technical and organizational measures pursuant to Article 32.

In this context, the Agency can mention that it has found that AULA's messaging module is designed in such a way that in messages sent to multiple recipients, it is most obvious to reply to all individuals in the message thread. There is a less visible field where it is possible to reply directly to the sender of the message. However, in the field where the user replies to all in the message thread, there is information about how many individuals the user is replying to. Such a design of the messaging function, in the Agency's opinion, entails a risk that users of AULA inadvertently send a message to all recipients in a message thread instead of solely to the sender of the message. In this regard, there is a risk that sensitive or confidential personal data is unlawfully disclosed to incorrect recipients.

Furthermore, the Data Protection Agency has found that recipient suggestions are automatically generated when the user begins to type in the recipient field "To."

In this context, both employees, children, and parents are suggested as recipients. This, in the Agency's view, entails a risk that users select one or more incorrect recipients from the list of suggested recipients, or that they select, for example, all suggested parents whose first name or last name contains the entered letters, instead of one specific recipient.

4.1.6. Particularly Regarding Rights Management and Access Control

It is the Data Protection Agency's view that the requirement pursuant to Article 32 for appropriate security will generally imply that user access to systems is limited to the personal data necessary for the respective users' needs.

In this context, the Agency notes that rights management in systems with personal data must prevent unauthorized access to personal data as well as unauthorized alteration or loss of personal data in the

system in cases where users have access to modify or delete information.

In this regard, it is the Agency's view that the requirement pursuant to Article 32 for appropriate security will generally entail that in systems containing a large number of confidential and sensitive data about a large number of individuals, higher demands must be placed on the data controller's diligence in ensuring that unauthorized access to personal data does not occur.

Moreover, it is the Agency's view that the requirement for appropriate security will generally entail that the data controller continuously checks whether access to systems and physical materials containing personal data is restricted to users who have a legitimate need for access to the information.

According to Article 32, paragraph 1, letter d, if relevant, procedures must be established for regular testing, assessment, and evaluation of the effectiveness of the technical and organizational measures to ensure processing security.

Periodic control (audit) should, depending on the circumstances, also include checks of authorizations and established accesses. It should be noted in this connection that a lack of periodic control (audit), in the Agency's opinion, entails an unnecessarily high risk that insufficient or inadequate access control is not identified in a timely manner.

Furthermore, it is the Agency's view that the control of access rights should at a minimum consist of a verification of the work-related need at the time of granting access, ongoing checks based on verification that this need is still present, and some form of auditing thereof. If the auditing is conducted as random checks, the number and frequency of selected samples must be representative in relation to the number of possible incidents and the risk to the rights of the data subjects.

4.1.7. Overall Assessment Regarding Risk Assessment

After a sample review of KOMBIT's risk assessment and a review of Frederikshavn Municipality's risk assessment in their impact analysis, the Data Protection Agency finds that Frederikshavn Municipality has demonstrated that it has identified and assessed the most significant risks that the municipality's processing of personal data in AULA poses to the data subjects.

Frederikshavn Municipality thus appears to have documented how they have assessed the risk to the data subjects from the relevant processing activities.

However, it is the Data Protection Agency's assessment that Frederikshavn Municipality has not demonstrated that the measures implemented to reduce the risk associated with the processing of personal data in AULA are sufficient to lower the risk from high to medium. Thus, it is the Agency's assessment that Frederikshavn Municipality has not sufficiently demonstrated that it has ensured a security level that is appropriate to the risks that...

the processing of personal data in AULA involves. The Data Protection Agency therefore expresses criticism that Frederikshavn Municipality's processing of personal data has not been carried out in accordance with the General Data Protection Regulation's Article 5, paragraph 2, in conjunction with paragraph 1, letter f, and Article 24, paragraph 1, in conjunction with Article 32, paragraph 1.

The Data Protection Agency has, in choosing a response, emphasized that Frederikshavn Municipality has conducted a risk assessment of AULA, where the municipality has worked with and attempted to reduce the identified risks. Frederikshavn Municipality has, as reported, in 2018 – and thus before the implementation of AULA – assessed whether KOMBIT's risk assessments were sufficient and whether they deviated from the municipality's assessments. However, it is only with the risk assessment in the municipality's impact analysis, dated November 3, 2022, that Frederikshavn Municipality has documented their assessments regarding the implementation of measures to reduce the high risks. This is almost three years after KOMBIT informed the municipalities about their data responsibility for AULA.

Frederikshavn Municipality's risk assessment in the impact analysis is, in the opinion of the Data Protection Agency, not sufficiently detailed, as the municipality has not addressed KOMBIT's assessment of which measures are necessary to reduce the high risks, and as the municipality has not addressed whether mitigating measures should be implemented concerning the 195 medium risks.

4.2. Impact Analysis

4.2.1. Requirement for Impact Analysis

It follows from the General Data Protection Regulation's Article 35, paragraph 1, that if a type of processing, particularly through the use of new technologies and by virtue of its nature, scope, context, and purpose, is likely to involve a high risk to the rights and freedoms of natural persons, the data controller shall carry out an analysis of the intended processing activities' consequences for the protection of personal data prior to the processing. A single analysis may cover several similar processing activities that involve similar high risks.

In the Article 29 Working Party's (now the European Data Protection Board, EDPB) guidelines on impact analysis concerning data protection, criteria have been established that can help identify the processing activities that will require an impact analysis. It follows from the guidelines that a data controller in most cases can assume that processing that meets two of the criteria must be subject to an impact analysis concerning data protection.

The processing of personal data in AULA meets two of these criteria, as sensitive and confidential personal data about vulnerable data subjects, including children, is processed. Furthermore, it is a system used for collaboration and communication between schools/daycare institutions and children and their parents. In the system, personal data is exchanged in messages, among other things, and there are many users associated with the system. It is the opinion of the Data Protection Agency that this communication entails a risk that, due to human errors, personal data may be inadvertently disclosed to incorrect users. This is particularly noted considering that the users consist of both employees in the municipality as well as children and their parents, and that, regardless of guidance, human errors will occur for which there are no immediate mitigating measures.

Generally, based on the types of information processed in AULA, the volume of information, the number of transactions (exchange of information in connection with communication), and the diversity of users in composition, there is not only a potential risk that the risk scenario will occur but also a real one.

The consequences for the rights of the data subjects can, in the opinion of the Data Protection Agency, range across almost the entire scale of severity of consequences, from the less intrusive, such as receiving unintended messages, to more serious ones, such as significant loss of reputation, to the most extreme consequence where a data subject's life is endangered by the disclosure of a concealed address, to mention just a few possible consequences.

The Data Protection Agency notes that any risk that involves a high consequence for the rights and freedoms of data subjects – even with relatively low probabilities of the risk materializing – will likely entail a high risk for the rights of data subjects, which triggers the obligation to carry out an impact analysis concerning data protection, cf. the Regulation's Article 35, paragraph 1.

Furthermore, based on reports of breaches of personal data security concerning AULA, the Data Protection Agency has generally found that several of these would likely involve a high risk to the rights and freedoms of natural persons. Additionally, the Agency has in several cases found that municipalities have considered the conditions in Article 34 to be met and have notified the data subjects about breaches of personal data security in AULA. The municipalities in question have thus assessed that the breaches likely would involve a high risk to the rights and freedoms of natural persons.

Based on the above, the Data Protection Agency agrees with Frederikshavn Municipality's assessment that the processing of personal data in AULA involves a high risk to the rights and freedoms of natural persons. The Data Protection Agency therefore finds that the processing activities carried out in AULA are subject to the requirement for an impact analysis concerning data protection prior to the implementation of AULA.

4.2.2. Timing of the Preparation of the Impact Analysis

It follows from the General Data Protection Regulation's Article 35, section 1, that a consequence analysis regarding data protection must be conducted prior to the processing. The Data Protection Agency assumes that Frederikshavn Municipality's consequence

analysis was prepared on November 3, 2022, as this date is noted on the front page of the consequence analysis.

The Data Protection Agency has, in connection with a supervisory visit to KOMBIT in December 2019, established that there has been uncertainty regarding where the data responsibility for the processing of personal data in the solution is placed. Both the municipalities and KOMBIT have thus been of the opinion that the data responsibility for the processing of personal data in AULA – and thus also the responsibility for conducting risk assessments and consequence analyses – was placed with KOMBIT.

As stated above under item 1, the Data Protection Agency has determined during the relevant supervisory visit to KOMBIT that KOMBIT is not to be regarded as data responsible, and therefore the supervision informed KOMBIT that KOMBIT must ensure that all municipalities are informed of their data responsibility, and that KOMBIT must transfer all necessary materials and information to the municipalities in that regard.

The Data Protection Agency assumes that this uncertainty regarding data responsibility has been a reason why Frederikshavn Municipality's consequence analysis was not prepared prior to their processing of personal data in AULA. In this context, the Data Protection Agency assumes that Frederikshavn Municipality, upon the implementation of AULA, believed that KOMBIT was data responsible for the processing of personal data in the solution and thus also responsible for the preparation of a risk assessment and consequence analysis.

Based on the Data Protection Agency's supervisory visit to KOMBIT in December 2019 and the material submitted by KOMBIT in that connection, the Data Protection Agency assumes that KOMBIT, in connection with the development of AULA – and before it was established that the municipalities were data responsible – conducted assessments of the risks and consequences for the registered individuals regarding the processing of personal data in AULA, which show that the processing entails a high risk for the registered individuals.

It is thus the Data Protection Agency's opinion that Frederikshavn Municipality – like the other municipalities – should have recognized the high risk associated with the processing of personal data in AULA in connection with KOMBIT informing the municipalities of their data responsibility regarding the processing of personal data in AULA and transferring all necessary materials in that connection. It is the Data Protection Agency's expectation that KOMBIT informed the municipalities about this immediately after the supervisory visit in December 2019.

However, the Data Protection Agency can ascertain that Frederikshavn Municipality is only seen to have prepared a consequence analysis in November 2022, and thus almost three years after there was clarity regarding data responsibility for AULA. The Data Protection Agency can also ascertain that the consequence analysis was prepared after the Data Protection Agency requested the material as part of the written supervision in the area.

It is the Data Protection Agency's opinion that Frederikshavn Municipality, upon the establishment of the municipality's data responsibility for the processing of personal data in AULA, as well as the high risk that the processing entails, should have commenced the preparation of a consequence analysis.

The Data Protection Agency has particularly taken into account in its assessment that the purpose of a consequence analysis is to determine the specific risks associated with the processing for the rights and freedoms of the registered individuals and subsequently to ensure that – before the processing begins – measures are established to mitigate these risks and reduce the risk to a level that is less than high.

On this basis, the Data Protection Agency finds that Frederikshavn Municipality, by only having prepared a consequence analysis for the processing of personal data in AULA almost three years after the municipality became aware that they are data responsible for the processing of personal data in a solution that entails a high risk for the registered individuals, has acted contrary to the provisions of Article 35, section 1 of the Data Protection Regulation.

4.2.3. Minimum requirements for consequence analyses

Article 35 of the Data Protection Regulation contains a number of requirements that a consequence analysis must meet at a minimum. These requirements follow from section 7 and include the following:

- a systematic description of the planned processing activities and the purposes of the processing, including, where applicable, the legitimate interests pursued by the data controller
- an assessment of whether the processing activities are necessary and proportionate to the purposes
- an assessment of the risks to the rights and freedoms of the registered individuals as referred to in section 1, and
- the measures that are intended to address these risks, including safeguards, security measures, and mechanisms that can ensure the protection of personal data and demonstrate compliance with this regulation, taking into account the rights and legitimate interests of the registered individuals and other affected persons.

The rules of the Data Protection Regulation regarding consequence analyses are intended to ensure that no processing, where there is an inherent high risk to the rights and freedoms of the registered individuals, is initiated without the data controller having worked on and mitigated such risks.

A consequence analysis regarding data protection is thus a tool that enables the data controller to work with the risks that a...

processing activities may involve, in a systematic manner.

The Data Protection Regulation provides data controllers with the flexibility to determine the exact structure and form of the data protection impact assessment. However, regardless of the form, a data protection impact assessment must include the above minimum requirements and thus be a proper assessment of risks that enables data controllers to take measures to mitigate them.

The Data Protection Authority has reviewed the data protection impact assessment of Frederikshavn Municipality in relation to the minimum requirements in Article 35, paragraph 7 of the Data Protection Regulation. It is the Authority's overall assessment that Frederikshavn Municipality has not conducted a satisfactory data protection impact assessment, cf. Article 35, paragraph 1 of the Data Protection Regulation, as the submitted impact assessment does not meet the minimum requirements set out in Article 35, paragraph 7, letters a and d of the Regulation.

Below follows the Data Protection Authority's assessment of the impact assessment in relation to the individual minimum requirements set forth in Article 35, paragraph 7, letters a-d.

Ad a) Systematic description of processing activities and purposes

It is the Data Protection Authority's opinion that the requirement for a systematic description of the planned processing activities and the purposes of the processing, cf. Article 35, paragraph 7, letter a of the Data Protection Regulation, entails that data controllers must provide a systematic description of the various forms of processing, e.g., collection, registration, disclosure, etc., that personal data will be subject to, as well as a clear description and definition of the personal data being processed.

Furthermore, the requirement entails that the impact assessment must include a description of the purpose of the processing.

Additionally, the Data Protection Authority believes that a systematic description should include information about the legal basis for the processing (authority), which categories of data subjects the information pertains to, the number of data subjects, information about where the data comes from, who – within and outside the organization – can access the data, how long the data is retained, whether there is a transfer of data to third countries (and on what basis), and whether new technologies are used for the processing of personal data.

Thus, the systematic description should contribute to the data controller's assessment of the specific likelihood and severity of high risks, taking into account the nature, scope, context, and purposes of the processing as well as the sources of risk. In this connection, the Data Protection Authority refers to recital 90[8].

Frederikshavn Municipality's impact assessment includes, among other things, information about the legal basis for the processing, categories of data subjects whose information is processed in AULA, information about where the data comes from, which staff groups within the organization have access

to data in AULA, how long personal data is processed (temporal extent), and a statement that no new technology is used for the processing of personal data.

Regarding the transfer of personal data to third countries, it is stated that all processing of personal data that Netcompany performs in relation to AULA occurs within the EU/EEA, and that no personal data is transferred to third countries when using Amazon Web Services (hereinafter AWS). In this context, it is noted that a dialogue has been initiated between AWS, Netcompany, and KOMBIT regarding the issue of intended/unintended transfers to third countries, following a meeting between the Data Protection Authority, KL, and Kombit, and that this dialogue was ongoing at the time of the update of the impact assessment.

The impact assessment indicates that personal data is collected, including how the data is collected and what the sources of the data are. Furthermore, it describes how data from other registers is used. However, the impact assessment does not contain a systematic description of the various forms of processing in AULA, e.g., registration, disclosure, etc., that personal data will additionally be subject to. Frederikshavn Municipality's impact assessment includes a specification of what types of personal data are processed in AULA. It is stated that both ordinary and sensitive personal data, as well as CPR numbers, are processed in AULA. It is further specified which contact information is processed and that it is possible to upload a profile picture. It is also noted that individual institutions choose which additional data about the child they need to ask users to fill out, and that this is reported as supplementary basic data or permissions.

Regarding the special categories of personal data (sensitive personal data), Frederikshavn Municipality indicates that sensitive personal data will occur in messages and the "secure file sharing" module. However, it is not specified what sensitive personal data, e.g., health information or information about religious beliefs, may be contained in messages and the "secure file sharing" module. It is the Data Protection Authority's understanding that it is the users of AULA, including parents and students, who use these modules in their communication with schools or daycare institutions, and that the municipality therefore cannot necessarily predict exactly what examples of sensitive personal data the modules will contain.

However, it is the Data Protection Authority's opinion that Frederikshavn Municipality, in their description of the processing activities, can base their assessment on their experiences regarding what types of information messages from educational staff, etc., to parents and...

text that the municipality has conducted a data protection impact assessment. However, it is Datatilsynet's assessment that the documentation does not sufficiently demonstrate that the municipality has adequately consulted with the data protection officer regarding the impact assessment.

4.2.5. Conclusion

In conclusion, Datatilsynet finds that Frederikshavn Municipality's data protection impact assessment does not meet the minimum requirements set out in Article 35, paragraphs 7(a), 7(b), 7(c), and 7(d) of the General Data Protection Regulation. The assessment lacks sufficient detail regarding the processing activities, the necessity and proportionality of the processing, the risks to the rights and freedoms of the data subjects, and the measures taken to mitigate those risks. Furthermore, it appears that the municipality did not adequately consult with the data protection officer as required by the regulation.

Datatilsynet recommends that Frederikshavn Municipality revises its data protection impact assessment to address these deficiencies and ensure compliance with the General Data Protection Regulation.

****4.2.5. Overall Assessment Regarding the Impact Assessment****

It is the Data Protection Authority's assessment that Frederikshavn Municipality has not conducted a sufficient impact assessment, cf. Article 35, paragraph 1 of the General Data Protection Regulation (GDPR), as the submitted impact assessment does not meet the minimum requirements set out in Article 35, paragraph 7, letters a and d of the Regulation. Furthermore, the Data Protection Authority finds that Frederikshavn Municipality, by only having prepared an impact assessment for the

processing of personal data in AULA nearly three years after it became clear that the municipality is the data controller for the processing of personal data in a solution that entails a high risk for the data subjects, has acted in violation of Article 35, paragraph 1 of the GDPR. The Data Protection Authority considers it serious that the impact assessment appears to have been prepared only after the Data Protection Authority requested the material as part of the written supervision in the area.

On this basis, the Data Protection Authority finds grounds to express serious criticism that Frederikshavn Municipality's processing of personal data has not been carried out in accordance with Article 35, paragraph 1 of the Regulation. The Data Protection Authority has, in choosing a response, emphasized that Frederikshavn Municipality has prepared an impact assessment for the processing of personal data in AULA, which contains the elements specified in Article 35, paragraph 7, letters a-d.

However, in the Data Protection Authority's opinion, Frederikshavn Municipality's impact assessment is not sufficiently detailed. In this regard, the Data Protection Authority notes that a systematic description of the processing activities must contribute to the data controller's assessment of the specific likelihood and severity of the high risks, taking into account the nature, scope, context, and purpose of the processing as well as the sources of risk. Furthermore, the content of the impact assessment regarding the identification of measures to address the identified risks is not sufficient to meet the minimum requirement in Article 35, paragraph 7, letter d. The Data Protection Authority has also emphasized the timing of Frederikshavn Municipality's preparation of the impact assessment.

The Data Protection Authority notes that the purpose of an impact assessment is to determine the specific risks associated with the processing for the rights and freedoms of the data subjects and subsequently ensure that measures are established to mitigate these risks and reduce the risk to a level that is less than high before the processing begins. It is the Data Protection Authority's opinion that Frederikshavn Municipality should have commenced the preparation of an impact assessment already upon determining the municipality's data responsibility for the processing of personal data in AULA and the high risk that the processing entails.

****4.3. Summary****

On the basis of the above, the Data Protection Authority finds grounds to express criticism that Frederikshavn Municipality's processing of personal data has not been carried out in accordance with Article 5, paragraph 2, cf. paragraph 1, letter f, and Article 24, paragraph 1, cf. Article 32, paragraph 1 of the General Data Protection Regulation. The Data Protection Authority further finds grounds to express serious criticism that Frederikshavn Municipality's processing of personal data has not been carried out in accordance with Article 35, paragraph 1 of the Regulation.

****4.4. General Remarks by the Data Protection Authority****

In system landscapes where multiple data controllers use the same systems and perform approximately the same processing of personal data, there can be significant synergy in conducting joint assessments regarding risk factors, potential impact assessments, and mitigating measures. The Data Protection Authority notes that it may be relevant to conduct a joint impact assessment if several data controllers plan to implement a common IT system or processing platform, for example, within the municipal sector. For multiple data controllers to collaborate on preparing a joint impact assessment, it is a prerequisite that the same type of system is involved, the same processing activity of the same personal data, and that the processing activities entail similar high risks.

It is not crucial that there is full identity between the systems and processing activities, but that the system, data, and particularly the processing activities do not deviate significantly from one another. Otherwise, a supplement to the joint impact assessment must necessarily be prepared. Thus, it is the Data Protection Authority's opinion that it would be sufficient for several municipalities to prepare one impact assessment regarding data protection for the processing of personal data in the same system, provided by the same supplier, if the same processing activities are performed in the system, the same types of personal data are processed, and the processing activities entail the same high risks.

It is the data controllers who specifically assess whether a joint impact assessment can be conducted for the processing activities in the systems. The data controllers in a joint...

****Consequence Analysis****

Each party is responsible for conducting the consequence analysis.[9] It is the opinion of the Data Protection Agency that, in relation to the municipalities' processing of personal data in AULA, the municipalities use the same type of system for the same processing activities of the same types of personal data, and that the municipalities' processing activities involve similar high risks. Furthermore, the system is provided by the same supplier. The municipalities thus have the opportunity to prepare a joint consequence analysis regarding data protection for their processing of personal data in AULA.

In associations and bodies that represent categories of data controllers, it may also be beneficial to develop a code of conduct in accordance with Article 40 of the General Data Protection Regulation to specify the application of the General Data Protection Regulation. A code of conduct can provide correct and practical guidance on how to organize oneself in connection with one or more processing activities to comply with data protection rules. This could, for example, involve establishing procedures that must be followed for a specific processing activity. A code of conduct would therefore be a useful tool to assist in complying with data protection rules for the authorities that have subscribed to the code. This facilitates compliance with the rules but does not relieve the individual data controller of the obligations and tasks that rest with them as data controllers. This is particularly significant in situations where the data controller chooses to deviate from the assumptions in the common concepts and processing, for example, by using a system for other purposes.

On this basis, the Data Protection Agency encourages consideration across municipalities and possibly in collaboration with KL and KOMBIT to develop a code of conduct in accordance with Article 40 of the General Data Protection Regulation regarding the municipalities' processing of personal data in AULA. This may also be relevant to consider in relation to other processing activities in the municipalities, where the municipalities use the same system for processing the same types of personal data for the same purposes.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

[2] Act No. 502 of May 23, 2018, on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data (Data Protection Act).

[3] KL has described the User Portal Initiative on their website: <https://www.kl.dk/kommunale-opgaver/boern-og-unge/digitalisering-paa-boerne-og-ungeomraadet/brugerportalsinitiativet/>

[4] KOMBIT provides information about AULA on the website <https://aulainfo.dk/om-aula/>

[5] It appears from material about the User Portal Initiative, which is available on KL's website: <https://www.kl.dk/media/11560/illustration-af-aftaler-om-databehandling-i-og-omkring-bpi.pdf>

[6] <https://aulainfo.dk/wp-content/uploads/Sletteprocedurer-og-sletteregler-i-Aula-v1.0.pdf>

[7] Guidelines for consequence analysis regarding data protection (DPIA) and determining whether the processing "likely involves a high risk" under Regulation (EU) 2016/679, WP248 rev. 01, adopted on April 4, 2017, as last revised and adopted on October 4, 2017.

[8] From recital 90, it states: "In such cases, the data controller should carry out a consequence analysis regarding data protection prior to processing to assess the specific likelihood and severity of the high risks, taking into account the nature, scope, context, and purposes of the processing as well as the sources of risk. The consequence analysis should particularly include the measures, safeguards, and mechanisms that are planned to mitigate this risk, to ensure the protection of personal data, and to demonstrate compliance with this regulation."

[9] Reference is made to the Data Protection Agency's guidance on consequence analysis from March 2018.